Analisando falhas nas políticas de acesso condicional (CAP) do Entra ID no Splunk

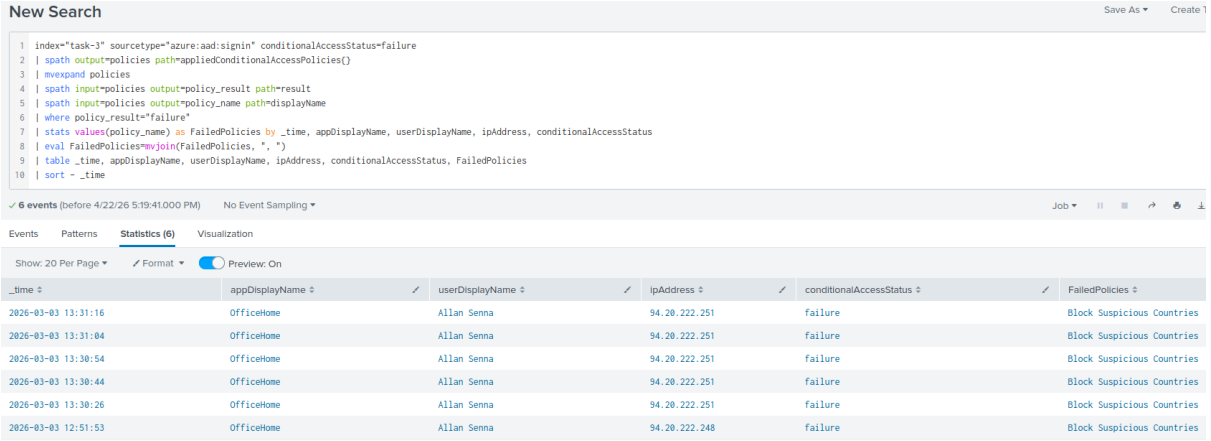
Um ataque de força bruta bem-sucedido pode fornecer credenciais válidas a um invasor. O que os impede de acessar o sistema imediatamente? Na maioria dos tenants do Entra ID, a resposta é uma combinação de dois controles: Políticas de Acesso Condicional e Proteção de Identidade. Compreender ambos e seus pontos cegos é essencial para um analista, pois os invasores buscam ativamente por brechas nesses controles, e seus logs indicarão quando encontrarem uma.

Pense nas Políticas de Acesso Condicional (CAP) como o mecanismo "se/então" do Entra ID. Cada login é avaliado em relação a um conjunto de políticas e, com base nas conclusões da política, o acesso é concedido, um controle adicional (como um controle de segurança) é exigido ou a solicitação é bloqueada completamente. Por exemplo, se uma empresa tiver usuários apenas em Londres e São Paulo, e um usuário se autenticar em Nova York, ele deverá concluir uma validação antes de acessar sua conta com sucesso.

É importante mencionar que uma política só é eficaz se abranger todas as suas áreas. Se não cobrir as contas e condições corretas, deixa lacunas que os atacantes procuram ativamente.

Iniciando análise através dessa consulta:

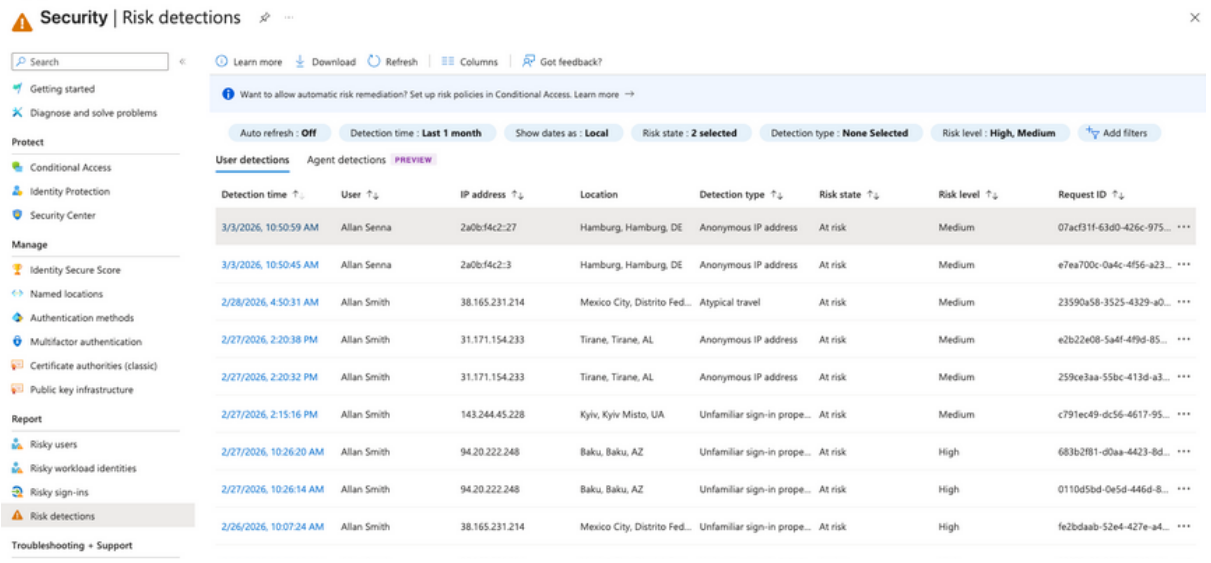
```
index="task-3" sourcetype="azure:aad:signin" conditionalAccessStatus=failure

| spath output=policies path=appliedConditionalAccessPolicies{}

| mvexpand policies

| spath input=policies output=policy_result path=result

| spath input=policies output=policy_name path=displayName

| where policy_result="failure"

| stats values(policy_name) as FailedPolicies by _time, appDisplayName, userDisplayName, ipAddress, conditionalAccessStatus

| eval FailedPolicies=mvjoin(FailedPolicies, ", ")

| table _time, appDisplayName, userDisplayName, ipAddress, conditionalAccessStatus, FailedPolicies

| sort - _time
```



Nesse teste aqui analisei vários logins realizados em países suspeitos.

Proteção de Identidade

O Acesso Condicional aplica suas regras, enquanto a Proteção de Identidade é o que informa ao Acesso Condicional quando algo parece suspeito. A Proteção de Identidade é o mecanismo de detecção de riscos baseado em aprendizado de máquina integrado ao Entra ID. Ele analisa continuamente o comportamento de login e os sinais da conta do usuário, atribui pontuações de risco e envia essas pontuações para o Acesso Condicional para que as políticas baseadas em risco possam agir de acordo.



Existem dois tipos de risco: **Risco de Login** e **Risco do Usuário**.

Ambos os tipos de risco usam uma escala de três níveis: Baixo, Médio e Alto.

Risco de Login

Avalia o grau de suspeita de uma tentativa de login específica.

Essa avaliação é feita em tempo real, para cada evento de autenticação. Abaixo estão exemplos do que aumenta o risco de login:

IP de Origem Suspeito: Login a partir de um IP conhecido por ser arriscado ou anônimo (por exemplo, Tor, serviços de proxy conhecidos ou provedores de VPN).

Viagem Impossível: Dois logins de locais geograficamente distantes dentro de um período de tempo impossível (por exemplo, primeiro login de Londres e, após 5 minutos, um login de Nova York).

Propriedades de Login Desconhecidas: Novo dispositivo, novo local ou novo ASN que não corresponde ao padrão histórico do usuário.

Esta página da Microsoft (abre em nova guia) documenta todos os tipos de risco.
Risco do Usuário

Avalia a probabilidade de uma conta específica ser comprometida.

Essa avaliação se acumula ao longo do tempo, com base no histórico da conta.
Exemplos:

Credenciais vazadas: Valida se a senha da conta apareceu em um vazamento de dados conhecido.

Múltiplos logins de alto risco: Verifica logins de risco relacionados que não foram corrigidos.

Atividade suspeita no Microsoft 365: Verifica possíveis atividades no Microsoft 365 após a violação (por exemplo, regras suspeitas na caixa de entrada).

O Entra ID possui um mecanismo de detecção de risco baseado em aprendizado de máquina integrado. Ele analisa continuamente o comportamento de login e os sinais da conta do usuário, atribui pontuações de risco e as envia para o Acesso Condicional para que as políticas baseadas em risco possam agir de acordo.

Proteção de identidade nos logs de entrada

Você pode procurar detalhes do log de Proteção de Identidade em três valores de sourcetype diferentes:

Logs de entrada (azure:aad:signin)

Para avaliar o nível de risco de uma tentativa de entrada específica, você pode usar o campo riskLevelDuringSignIn.

Para o risco cumulativo associado à conta de usuário como um todo, consulte riskLevelAggregated.

Abaixo está uma consulta Splunk que usa esses campos para analisar entradas de risco:

index="task-3" sourcetype="azure:aad:signin"

| where riskLevelDuringSignIn="high"

| table _time, userPrincipalName, appDisplayName, ipAddress, location.countryOrRegion, riskLevelDuringSignIn, riskLevelAggregated

| sort - _time

_time	userPrincipalName	appDisplayName	ipAddress	location.countryOrRegion	riskLevel
2026-03-03 13:51:03	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::27	DE	high
2026-03-03 13:51:02	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::27	DE	high
2026-03-03 13:51:01	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::27	DE	high
2026-03-03 13:51:01	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::27	DE	high
2026-03-03 13:51:00	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::27	DE	high
2026-03-03 13:50:59	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::3	DE	high
2026-03-03 13:50:59	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::27	DE	high
2026-03-03 13:50:46	allan.senna@finegalo.thm	My Apps	2a0b:f4c2::3	DE	high

Logs de Detecção de Riscos (azure:aad:riskdetection)

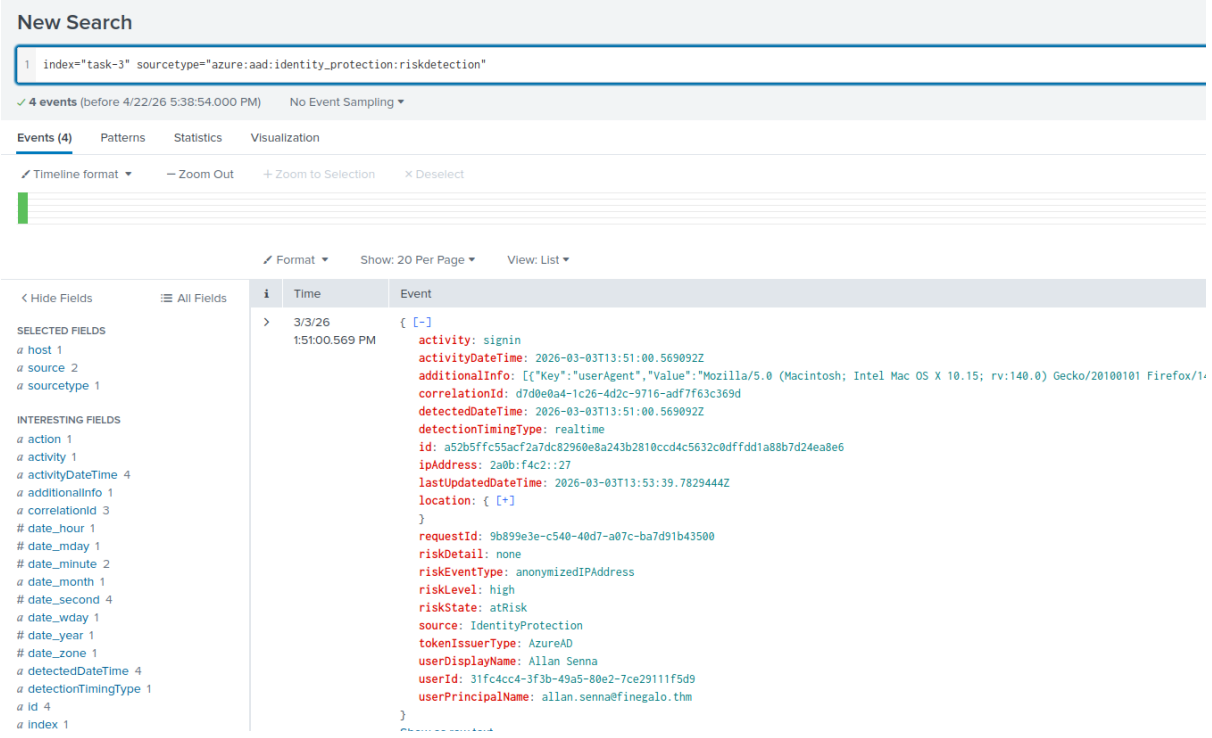
Este tipo de log é um registro detalhado gerado quando riscos são detectados. A diferença entre os campos de log de entrada regulares e os logs de entrada comuns reside nos detalhes adicionais relacionados à detecção, por exemplo: riskEventType: O tipo de risco identificado (por exemplo, anonymizedIPAddress, impossibleTravel). riskLevel: Indica o nível de risco da detecção. Esses logs também geram detecções em outras etapas de uso do M365 e do Entra ID, por exemplo, uma alteração de configuração suspeita realizada por um administrador. Você pode verificar o tipo de atividade que está sendo alertada consultando o campo activity. É importante ressaltar que você não deve confiar cegamente nas detecções de risco. Por exemplo, se nenhum alerta de viagem impossível for gerado, isso não significa

que a viagem não ocorreu. Sempre valide os logs de entrada quando suspeitar de comportamento do usuário ou ao realizar busca proativa de ameaças.

Abaixo estão duas consultas Splunk para analisar logs de detecção de risco:

1 - Listar todos os registros de detecção de risco.

index="task-3" sourcetype="azure:aad:identity_protection:riskdetection"



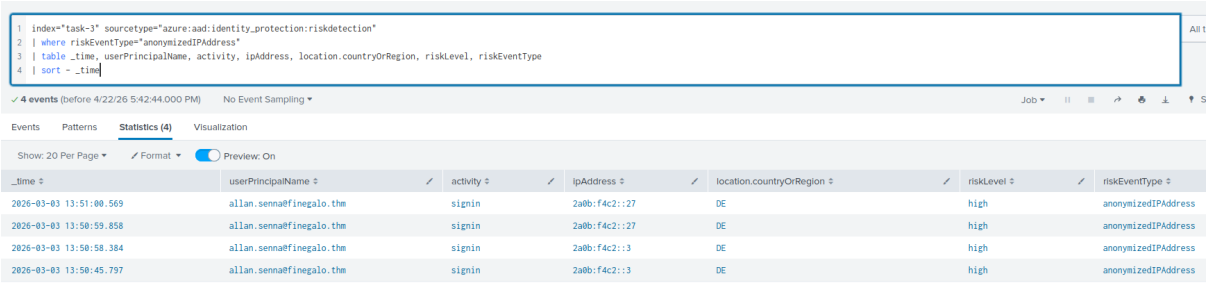
2 - Listar todas as detecções de risco relacionadas a IPs anonimizados.

index="task-3" sourcetype="azure:aad:identity_protection:riskdetection"

| where riskEventType="anonymizedIPAddress"

| table _time, userPrincipalName, activity, ipAddress, location.countryOrRegion, riskLevel, riskEventType

| sort - _time



```
index="task-3" sourcetype="azure:aad:identity_protection:riskdetection"
| where riskEventType="anonymizedIPAddress"
| table _time, userPrincipalName, activity, ipAddress, location.countryOrRegion, riskLevel, riskEventType
| sort - _time
```

✓ 4 events (before 4/22/26 5:42:44.000 PM) No Event Sampling

Events Patterns Statistics (4) Visualization

Show: 20 Per Page Format Preview: On

_time	userPrincipalName	activity	ipAddress	location.countryOrRegion	riskLevel	riskEventType
2026-03-03 13:51:00.569	allan.senna@finegalo.thm	signin	2a0b:f4c2::27	DE	high	anonymizedIPAddress
2026-03-03 13:50:59.858	allan.senna@finegalo.thm	signin	2a0b:f4c2::27	DE	high	anonymizedIPAddress
2026-03-03 13:50:58.384	allan.senna@finegalo.thm	signin	2a0b:f4c2::3	DE	high	anonymizedIPAddress
2026-03-03 13:50:45.797	allan.senna@finegalo.thm	signin	2a0b:f4c2::3	DE	high	anonymizedIPAddress

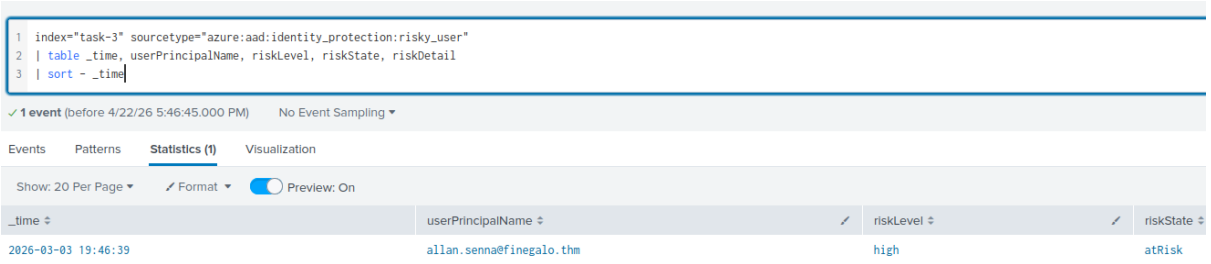
Registros de Usuários de Risco (azure:aad:identity_protection:risky_user)

Cada usuário possui um nível de risco no Entra ID. Esse nível é calculado com base nas detecções de risco e serve para que a Microsoft alerte os administradores sobre usuários que provavelmente foram comprometidos (ou quase foram comprometidos) e que precisam de atenção. Assim que um usuário altera seu nível de risco, um registro de usuário de risco é gerado. Isso torna esse tipo de registro um bom gatilho para realizar buscas proativas por ameaças e identificar usuários que provavelmente foram comprometidos. Abaixo, segue uma consulta Splunk para filtrar todos os registros de usuários de risco:

index="task-3" sourcetype="azure:aad:identity_protection:risky_user"

| table _time, userPrincipalName, riskLevel, riskState, riskDetail

| sort - _time



```
index="task-3" sourcetype="azure:aad:identity_protection:risky_user"
| table _time, userPrincipalName, riskLevel, riskState, riskDetail
| sort - _time
```

✓ 1 event (before 4/22/26 5:46:45.000 PM) No Event Sampling

Events Patterns Statistics (1) Visualization

Show: 20 Per Page Format Preview: On

_time	userPrincipalName	riskLevel	riskState
2026-03-03 19:46:39	allan.senna@finegalo.thm	high	atRisk

Prática

Nesta tarefa irei avaliar o risco de alguns logins e contas de usuário usando logs.

Endereço de e-mail do usuário encontrado que está em risco no tenant:

Usando essa consulta:

index="task-3" sourcetype="azure:aad:signin"

| where riskLevelDuringSignIn="high"

| table _time, userPrincipalName, appDisplayName, ipAddress, location.countryOrRegion, riskLevelDuringSignIn, riskLevelAggregated

| sort - _time

Descobri que o usuário que está em risco é: allan.senna@finegalo.thm

Última tentativa de login de risco desse usuário, com base nos registros de detecção de risco

Observando o horário percebi que o ultimo login foi: 2026-03-03 13:51:03

Tipo de risco identificado durante o login desse usuário de risco, com base nos registros de detecção de risco

Através dessa pesquisa:

index="task-3" sourcetype="azure:aad:identity_protection:riskdetection"

| where riskEventType="anonymizedIPAddress"

| table _time, userPrincipalName, activity, ipAddress, location.countryOrRegion, riskLevel, riskEventType

| sort - _time

verifiquei em ‘riskEventType’ que o tipo de risco era: anonymizedIPAddress

Nome da política CAP que foi aplicada e bloqueou algumas tentativas de login desse usuário de risco

O nome da política CAP que bloqueou as tentativas é: Block Suspicious Countries

Descobri usando essa consulta:

index="task-3" sourcetype="azure:aad:signin" conditionalAccessStatus=failure

| spath output=policies path=appliedConditionalAccessPolicies{}

| mvexpand policies

| spath input=policies output=policy_result path=result

| spath input=policies output=policy_name path=displayName

| where policy_result="failure"

| stats values(policy_name) as FailedPolicies by _time, appDisplayName, userDisplayName, ipAddress, conditionalAccessStatus

| eval FailedPolicies=mvjoin(FailedPolicies, ", ")

| table _time, appDisplayName, userDisplayName, ipAddress, conditionalAccessStatus, FailedPolicies

| sort - _time

Endereço IP que impediu o login desse usuário de risco

O IP é: 94.20.222.251

Descobri clicando em Failure e ViewEvents ao consultar a informação anterior.